



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



ServiceNow Hosted Instance API Security Incident

Executive Summary

Classification	TLP:CLEAR
Published	2026-06-10
Version	1.0
Author	Lost Boys Cyber
Report Type	Executive Summary

TLP:CLEAR | Lost Boys Cyber | ServiceNow Hosted Instance API Security Incident - Executive Summary

Published: 2026-06-10 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. BLUF
2. Expected Impact Statement
3. What Happened
4. Why It Matters
5. Confidence and Caveats
6. Immediate Actions for Defenders
7. Bottom-Line Assessment

ServiceNow Hosted Instance API Security Incident — Threat Intelligence

Executive Summary

Classification: TLP:CLEAR Published: 2026-06-10 Version: 1.0 Author: Lost Boys Cyber Report Type: Threat Intelligence
Executive Summary Severity: High

1. BLUF

Between 2-3 June 2026, attackers exploited a ServiceNow-hosted API access control failure to query data from a subset of customer instances before the vendor pushed a hosted fix on 5 June. Public reporting and multiple secondary sources consistently indicate the exposure was tied to an endpoint associated with `/api/now/related_list_edit/create` and a configuration state that allowed unauthenticated access. The most material enterprise risk is not only the direct exposure of tickets, employee records, workflow data, and security cases, but the secondary exposure of credentials, API tokens, integration secrets, and internal process knowledge commonly stored in ServiceNow records.

2. Expected Impact Statement

Expected impact is HIGH for directly affected tenants and MODERATE for the broader ServiceNow customer base. For affected organisations, likely consequences include regulatory notification pressure, third-party risk escalation, targeted follow-on intrusion using harvested secrets, and trust degradation around SaaS control boundaries. For customers not individually notified by ServiceNow, immediate platform compromise risk appears reduced after the 5 June hosted remediation, but log review, secret rotation for sensitive records, and validation of legacy/custom API exposure remain warranted.

3. What Happened

- ServiceNow applied a hosted security update on 5 June 2026 after identifying a security issue that could allow an unauthenticated user, in certain circumstances, to gain greater access to customer instances than intended.
- ServiceNow stated that, for a subset of customers, it observed evidence of successful queries of instance tables and opened direct support cases with affected customers.
- Public reporting consistently states the issue primarily affected customers on the Australia platform release or customers on pre-Australia releases who had made certain configuration changes.
- Community and third-party reporting strongly suggest the exposed path was ``/api/now/related_list_edit/create``, likely associated with a Scripted REST Resource configured in a way that did not require authentication.

4. Why It Matters

- ServiceNow instances often hold highly operational data rather than just generic support metadata: incident tickets, change records, employee information, asset inventories, security cases, workflow logic, and attachments.
- Tickets and support cases routinely contain sensitive implementation detail, including credentials, API tokens, architecture notes, and troubleshooting artefacts that can enable follow-on intrusion even when the original exposure appears "read only."
- This incident raises vendor-risk and compliance questions because public reporting indicates the underlying issue may have been known internally before the hosted remediation window, although that timing claim is not yet vendor-confirmed in a public source.

5. Confidence and Caveats

- High confidence: hosted remediation date (5 June 2026), successful table queries against a subset of customers, customer notification-by-case model, affected-scope language, and no public CVE assignment as of publication.
- Medium confidence: the exact endpoint path, the ``requires_authentication=false`` root-cause explanation, the use of the ``Guest`` context in logs, and the IP ``51.159.98.241`` as a primary hunt lead.
- Low-to-medium confidence: the additional IP ``86.245.155.105`` and claims that ServiceNow internally documented the issue on 7 April 2026.

6. Immediate Actions for Defenders

1. Confirm whether your organisation received a ServiceNow support case related to this incident.
2. Review ServiceNow transaction and node logs for 2-3 June 2026, focused on ``/api/now/related_list_edit/create``, ``Guest`` context events, and suspicious external IPs.
3. Review tickets, attachments, knowledge items, and workflow records that may have contained plaintext credentials, tokens, VPN configs, or sensitive architecture details.
4. Rotate any secrets that may have been exposed through records accessible from the affected instance.
5. Audit all custom and legacy Scripted REST Resources for authentication and ACL enforcement, even if ServiceNow stated no further customer action was required for hosted remediation.

7. Bottom-Line Assessment

This was not merely a routine SaaS bug fix. It was a confirmed security incident involving successful unauthorised queries against customer data inside a widely trusted enterprise workflow platform. Even where the directly exposed data volume is still unknown, the likely secondary risk from secrets embedded in operational records makes this incident materially more serious than a narrow metadata leak.